

SQL Injection Protection Guide

Overview

SQL Injection is a code injection technique where attackers insert malicious SQL statements into application inputs to manipulate the database. It is one of the most common and dangerous web security vulnerabilities.

Common Types

Error-based SQL injection, Union query injection, Boolean-based blind injection, Time-based blind injection, Stacked queries injection.

Protection Measures

1. Use parameterized queries 2. Use ORM frameworks 3. Input validation 4. Least privilege principle 5. Proper error handling

Python Example

Wrong: `query = f"SELECT * FROM users WHERE name = '{name}'"` Correct:
`cursor.execute("SELECT * FROM users WHERE name = %s", (name,))`